

AI-Augmented Governance of Non-Human Identities in DevSecOps Pipelines: A Systematic Review and Risk-Scoring Framework

Manu Prakash Bhat and Merin Meleet

Department of Information Science and Engineering, RV College of Engineering, Bengaluru 560059, Karnataka, India
manuprakashb.is22@rvce.edu.in, merinmeleet@rvce.edu.in

Abstract—Software delivery pipelines in contemporary enterprises depend on non-human identities (NHIs) — API tokens, service principal credentials, deploy keys, machine certificates — to authenticate automated processes in cloud-native environments. Recent telemetry from Entro Labs places the ratio of machine to human identities at 144:1 across enterprise estates, yet these credentials attract disproportionately little governance attention, leaving organizations with an attack surface that is both expanding and poorly mapped. We present a systematic review of 127 peer-reviewed publications, standards documents, and technical reports published between 2018 and 2026, organizing contributions along five governance dimensions: discovery, risk quantification, policy enforcement, remediation automation, and continuous monitoring. Building on the gaps this synthesis reveals, we propose a composite risk-scoring framework that fuses deterministic multi-factor assessment with optional large language model enrichment, producing normalized severity classifications across heterogeneous credential types on a unified 0–100 scale. No prior work renders disparate credential categories directly comparable in this fashion. We further describe a five-layer reference architecture whose modular construction permits individual components to be deployed, upgraded, or removed without disrupting the remaining pipeline. Evaluation across three organizational case studies demonstrates a 63% reduction in mean time to credential rotation, a 78% improvement in dormant identity detection, and policy compliance exceeding 94% within eight weeks of activation. We close by surveying open research problems, among them ephemeral credential risk modeling, cross-cloud identity federation governance, agentic AI identity management, and adversarial robustness of AI-augmented policy engines.

Index Terms—Non-human identity, DevSecOps, identity governance, risk scoring, machine credentials, certificate lifecycle, policy enforcement, large language models, cloud security, API token management, agentic AI.

I. INTRODUCTION

CONTINUOUS integration and continuous delivery pipelines have rewritten the rules of authentication across the software industry. A decade ago, human operators provisioned credentials by hand and reviewed access lists once a quarter. Today, DevSecOps environments rely on thousands of machine-to-machine credentials that operate around the clock with no human in the loop. Personal access tokens, OAuth application credentials, service principal secrets, deploy keys, TLS certificates, API keys, workload identity federation tokens — taken together, these non-human identities (NHIs) are the connective tissue holding automated software delivery together.

The scale of the problem has grown faster than most practitioners realize. Entro Labs’ H1 2025 NHI and Secrets Risk Report pegs the ratio of machine to human identities at 144:1 across enterprise environments, up sharply from 92:1 only twelve months earlier — a 44% year-over-year surge driven in part by the rapid adoption of agentic AI systems [41]. A 2025 Cloud Security Alliance survey found that 68% of responding organizations lacked a comprehensive machine-credential inventory, and 54% had experienced at least one security incident traceable to a compromised or mismanaged NHI in the preceding eighteen months [2]. Credential theft remains the dominant initial access vector: the 2025 Verizon Data Breach Investigations Report found stolen credentials in 22% of all confirmed breaches and in a striking 88% of basic web application attacks [42]. On the secrets-sprawl front, GitGuardian documented 23.8 million new hardcoded secrets on public GitHub repositories in 2024 — a 25% year-over-year increase — and found that 70% of secrets first detected in 2022 were still valid and active two full years later [38].

Why is governing NHIs qualitatively harder than governing human identities? Three factors stand out. Human identities benefit from mature frameworks — role-based access control, multi-factor authentication, periodic reviews, behavioral analytics — for which no NHI equivalents exist at comparable maturity. Machine credentials, meanwhile, tend to be static, long-lived, and susceptible to silent privilege creep through configuration drift. And the sheer heterogeneity of credential types (cloud provider APIs, version control platforms, container registries, IaC tools) means no single mechanism can cover all categories. An Aembit survey in 2024 confirmed the gap: 88.5% of organizations acknowledged that their non-human IAM practices fall behind what the threat landscape demands [43]. Gartner underscored the point at its December 2024 IAM Summit, designating NHI management a top-three CISO risk and a 2025 strategic trend [44].

Supply chain attacks targeting CI/CD credentials have escalated sharply. The Codecov bash uploader compromise of 2021, the CircleCI secret exfiltration of January 2023, the March 2025 compromise of the widely used `tj-actions/changed-files` action [52], and continued exploitation of overprivileged GitHub Actions tokens all illustrate the trend [4], [5]. Regulatory pressure is mounting in parallel: the EU Cyber Resilience Act and revised NIST guidance now mandate machine identity lifecycle controls [6].

Infrastructure-as-code adoption and GitOps have meanwhile diffused secret management responsibility from centralized security teams to individual development squads, fragmenting governance further [7].

Despite these pressures, academic coverage of NHI governance remains siloed. Certificate lifecycle research lives in the PKI community. API key security is discussed in web application venues. Service principal governance appears in cloud security publications. Secret sprawl detection is the province of software engineering researchers. No single review has attempted to stitch these threads together into a coherent governance framework for modern DevSecOps pipelines. Janani [53] recently proposed a unified identity framework treating identity as a continuum, but that work does not produce a normalized numeric score across credential types — precisely the capability practitioners need for triage.

We fill the gap with three contributions:

- 1) A systematic review of 127 publications covering identity governance, credential lifecycle management, certificate monitoring, and policy-as-code enforcement, organized across five governance dimensions.
- 2) A composite risk-scoring framework that yields normalized 0–100 severity scores across heterogeneous NHI types through weighted multi-factor assessment, with optional LLM enrichment for contextual explanation.
- 3) A layered reference architecture integrating modular discovery agents, deterministic scoring, declarative policy evaluation, AI orchestration, and multi-channel reporting into existing CI/CD workflows without impeding development velocity.

Section II supplies background on NHI types and DevSecOps security. Section III describes the review methodology. Section IV presents a taxonomy of governance approaches. Section V details the proposed scoring framework. Section VI describes the reference architecture. Section VII reports evaluation results. Section VIII discusses practical implications and threats to validity. Section IX identifies open research challenges. Section X concludes.

II. BACKGROUND AND RELATED CONCEPTS

A. Non-Human Identities: Definition and Taxonomy

A non-human identity is any credential, certificate, token, or piece of cryptographic material that automated processes, services, or machines use to authenticate against other systems without real-time human involvement [8]. Several distinct categories exist, each with its own lifecycle profile and risk characteristics.

Personal Access Tokens (PATs) are long-lived bearer tokens issued by platforms like GitHub, GitLab, and Azure DevOps for API authentication. Classic PATs carry coarse-grained scopes — full repository access, for example — whereas fine-grained variants restrict access to specific repositories and permission sets [9]. Because PATs commonly sit in CI/CD environment variables, any workflow step in the pipeline can read them, which makes leakage a persistent worry.

Service Principal Credentials let applications in cloud environments (Azure AD, AWS IAM, GCP) authenticate against

cloud APIs through client secrets or X.509 certificates. Teams tend to provision these at project kickoff and then forget about rotation altogether. Finding a service principal whose credentials have sat untouched for three or four years is common in practice [10].

Deploy Keys provide SSH-based authentication scoped to individual repositories, offering either read-only or read-write access. Unlike PATs, they are narrowly scoped, but most hosting platforms offer no built-in expiry mechanism, creating what amounts to an indefinite access grant [11].

SSL/TLS Certificates authenticate server identities and establish encrypted channels. Though not always classified alongside API tokens or deploy keys, they share the same lifecycle governance requirements: issuance, rotation, expiry monitoring, and revocation. A lapsed certificate can cause service outages, break trust chains, and open transient interception windows [12].

Actions Secrets and CI/CD Variables hold sensitive values consumed at pipeline runtime. Injected as environment variables, they may contain API keys, database passwords, signing certificates, or cloud tokens. Their security rests entirely on the platform’s isolation model and the organization’s rotation discipline [13].

B. DevSecOps and the Shift-Left Paradigm

DevSecOps embeds security throughout the software delivery lifecycle rather than bolting it on at the end [14]. Under the shift-left philosophy, security testing, policy enforcement, and compliance checks move as early as possible into development. Identity governance is particularly challenging in this context because NHIs are created during development, configured at deployment time, and consumed at runtime, touching every pipeline stage.

Policy-as-code has become the dominant way to express security requirements in version-controlled, testable, machine-evaluable form [15]. Open Policy Agent (OPA), HashiCorp Sentinel, and AWS Cedar all support declarative policy definitions evaluated against infrastructure and application configurations. A recent empirical study of policy-as-code adoption across open-source projects confirms that regulatory mandates such as GDPR, HIPAA, and the EU AI Act are accelerating uptake [16].

C. Large Language Models in Security Operations

Since 2023, large language models have been pressed into service for log analysis, vulnerability explanation, incident triage, and policy generation [17]. In NHI governance specifically, LLMs can translate raw risk scores into business-contextualized narratives that non-technical stakeholders actually consume; they can spot cross-finding correlations (coordinated staleness across a team’s credentials hinting at a broken process); and they can draft remediation playbooks tailored to organizational context [18]. Al Haddad et al. evaluated four LLMs across 12 prompting techniques for vulnerability triage and found meaningful variation in severity-assessment accuracy, with some configurations approaching expert-level performance [55].

That said, hallucination, prompt injection, and over-reliance on probabilistic outputs for decisions that demand determinism remain real concerns. The consensus in the literature favors a *deterministic-first* design: AI enriches and explains, but never serves as the sole basis for enforcement [19].

D. Agentic AI as an Emerging NHI Class

A category of NHI that the existing literature has barely addressed is the autonomous AI agent. Unlike a traditional service account that performs deterministic, pre-programmed tasks, an agentic AI system can make its own decisions, spawn child agents, and acquire new access dynamically during task execution. The OpenID Foundation's October 2025 whitepaper on identity management for agentic AI highlights several governance challenges unique to this class: nested delegation chains where agents act on behalf of other agents rather than humans, short-lived but highly privileged access patterns that defy age-based scoring, and the difficulty of attributing actions when they fall somewhere between human direction and machine autonomy [45].

A Cloud Security Alliance survey conducted in late 2025 found that 40% of enterprise organizations already run autonomous AI agents in production, with another 31% operating pilots [46]. Yet only 18% of respondents expressed high confidence that their current IAM stack could manage agent identities effectively. The most common authentication method in use for agents remains static API keys and shared service accounts — the same patterns that fuel NHI breaches in traditional automation. OWASP published its first Top 10 for Agentic Applications in December 2025, cataloguing risks that include goal hijacking, tool misuse, identity abuse, and cascading failures [47]. These developments confirm that any governance framework proposed today must be explicitly extensible to the agentic identity class.

E. Ephemeral Workload Identity

Static, long-lived credentials are increasingly viewed as incompatible with zero-trust principles. A growing body of work advocates for secretless authentication through Workload Identity Federation (WIF) and OpenID Connect (OIDC) [48]. In this model, a CI/CD job receives a short-lived OIDC token at execution time and exchanges it for a scoped access token in the target platform; no static secret ever touches disk. The SPIFFE (Secure Production Identity Framework for Everyone) specification extends this idea to runtime workloads, providing a platform-neutral, policy-driven identity model for non-human actors [49].

These developments have direct implications for risk scoring. A token that expires in minutes cannot be evaluated on a staleness dimension. What matters instead is the security posture of the identity-provider chain, the scope breadth of each issuance, and the issuance frequency itself. We return to this limitation explicitly in Section V.

III. SYSTEMATIC REVIEW METHODOLOGY

A. Research Questions

Five questions guided this review:

- RQ1.** What mechanisms exist for discovering non-human identities across heterogeneous DevSecOps environments?
- RQ2.** How are NHI-related risks quantified, and what scoring models have been proposed?
- RQ3.** Which policy enforcement approaches govern NHI life-cycles?
- RQ4.** To what extent has AI/ML been applied to automate NHI governance?
- RQ5.** What reference architectures integrate NHI governance into CI/CD pipelines?

B. Search Strategy

We searched IEEE Xplore, ACM Digital Library, Springer Link, ScienceDirect, arXiv, and Google Scholar using the composite query:

("non-human identity" OR "machine identity" OR "service account" OR "API key" OR "deploy key" OR "personal access token" OR "certificate lifecycle") AND ("DevSecOps" OR "CI/CD" OR "DevOps" OR "pipeline security" OR "identity governance" OR "credential management")

Coverage spans January 2018 through March 2026, coinciding with the maturation of both DevSecOps practice and cloud-native identity tooling.

C. Inclusion and Exclusion Criteria

A publication qualified for inclusion if it addressed at least one NHI type within an automated delivery or cloud operations context. We excluded work focused solely on human identity management, vendor marketing that lacked technical substance, and non-English publications.

D. Selection Results

Our search returned 843 candidates. Title-and-abstract screening left 291. Full-text assessment against the inclusion criteria produced a final corpus of 127 publications: 47 journal articles, 52 conference papers, 14 standards-body technical reports, and 14 industry whitepapers from organizations including NIST, the Cloud Security Alliance, and the OWASP Foundation.

IV. TAXONOMY OF NHI GOVERNANCE APPROACHES

Analysis of the corpus reveals five governance dimensions that together define the NHI management lifecycle. We discuss each in turn, citing representative work and noting limitations.

A. Dimension 1: Discovery and Inventory

You cannot govern what you cannot see. Three discovery paradigms dominate the literature.

API-driven enumeration. Platform APIs are queried directly. GitHub's REST and GraphQL endpoints expose PATs, deploy keys, Actions secrets metadata, and App installations [20]. Microsoft Graph enumerates service principals, application registrations, and managed identities [21]. AWS IAM APIs

cover users, roles, and access keys [22]. The strength is completeness within a single platform; the weakness is that every platform requires a bespoke integration, and APIs change.

Configuration scanning. IaC templates, CI/CD workflow files, and application config are parsed for credential references. Patterns like `{{ secrets.NAME }}` in GitHub Actions or `vault://path/to/secret` in HashiCorp files reveal where secrets are consumed [23]. Basak et al. benchmarked five open-source and four proprietary detection tools and found that GitHub Secret Scanner achieved the highest precision (75%), while Gitleaks reached the highest recall (88%); false positives arose primarily from overly broad regular expressions and flawed entropy calculation [50]. Configuration scanning exposes the dependency graph between identities and consumers but cannot verify whether a referenced credential is still active without an API call.

Network traffic analysis. By observing authentication patterns at the network layer — repetitive requests, fixed source IPs, absence of interactive session markers — analysts can spot NHIs through behavioral signatures [24]. The approach can surface shadow credentials invisible to centralized inventories, though it demands network instrumentation and raises privacy questions in shared tenancies.

B. Dimension 2: Risk Quantification

Heterogeneous credentials require a common yardstick. Four model families appear in the literature.

Age-based models use credential age relative to a rotation threshold as the sole risk indicator [25]. Simple and deterministic, but blind to privilege: a 200-day-old read-only deploy key may well pose less risk than a freshly minted admin token.

Scope-weighted models assign risk proportional to the breadth and sensitivity of granted permissions [26]. Google Cloud's H1 2025 Threat Horizons Report supplies compelling justification: overprivileged service accounts triggered 46.4% of cloud security alerts in H2 2024 and enabled 62.2% of lateral movement incidents [54]. The approach captures blast radius well but ignores temporal accumulation.

Composite models blend age, scope, identity type, usage patterns, and environmental context into a weighted aggregate [27]. They paint the richest risk picture but demand careful weight calibration. The literature offers no consensus on optimal weight distributions.

ML-enhanced models apply anomaly detection or supervised classification to flag credentials deviating from behavioral baselines [28]. They catch risks invisible to rule engines (a token suddenly accessing repos outside its historical scope), but need sufficient training data and produce probabilistic outputs that may not satisfy compliance mandates for deterministic audit trails.

C. Dimension 3: Policy Enforcement

Quantified risk needs to trigger automated responses.

Declarative policy engines. OPA evaluates NHI metadata against Rego-language rules covering age thresholds, prohibited scope combinations, and dependency constraints [29].

Because policy is code, it can be versioned, peer-reviewed, and unit-tested alongside application logic.

Event-driven enforcement. Rather than polling on a schedule, event-driven systems fire when a credential is created, modified, or nearing expiry [30]. Azure Event Grid, AWS EventBridge, and GCP Pub/Sub all emit lifecycle events enabling sub-minute response.

Preventive controls. Policy is enforced at the point of credential creation, blocking non-compliant configurations before they exist [31]. Pan et al. conducted a large-scale measurement across 320,000 GitHub repositories and found that CI/CD pipelines depend heavily on a handful of core scripts, creating single points of failure; the same pipelines contain sensitive information that makes them high-value targets [51]. Wessel et al. analyzed reusable GitHub Actions and their dependencies as a key vulnerability surface, observing poor permission management and command injection risks [52]. Preventive controls such as Kubernetes admission controllers and Azure AD conditional access address exactly these vectors.

D. Dimension 4: Remediation Automation

Detection without correction is noise. Three strategies appear.

Rotation automation generates new credential values, updates consumers, validates correct operation, and revokes old material [32]. HashiCorp Vault dynamic secrets, Azure Key Vault auto-rotation, and AWS Secrets Manager rotation Lambdas are representative implementations. The hard problem is coordination: when multiple services share a credential, partial rotation breaks things.

Scope reduction adjusts permissions to match actual usage, retroactively enforcing least privilege [33]. Cloud access-advisor features recommend specific cuts. Automation requires high confidence in usage-log completeness, since a false negative would disrupt a legitimate workflow.

Deprovisioning removes credentials that have seen no activity within an observation window, eliminating dormant attack surface [34]. The risk is clipping a credential that only fires during infrequent operations (disaster recovery, annual audits), which is why most deployments insert a human approval step before final revocation.

E. Dimension 5: Continuous Monitoring and Reporting

Governance is not a one-time exercise. Sustained posture requires ongoing monitoring.

Dashboard visualization presents severity distributions, expiry timelines, and compliance trends through interactive interfaces [35]. Good dashboards serve multiple audiences: security engineers want finding-level drill-downs, management wants posture summaries, auditors want compliance evidence.

Multi-channel alerting routes notifications via channels matched to severity [36]. Critical findings hit pagers and incident management systems; medium-severity items land in email digests or ticketing queues; low-severity observations accumulate silently in dashboards.

Trend analysis applies statistical methods to historical data, surfacing patterns like a business unit's steadily rising credential age (process failure), seasonal compliance dips tied to release cycles, or repeated violations concentrated in one team [37].

Table I consolidates the five dimensions.

V. COMPOSITE RISK-SCORING FRAMEWORK

The review exposes a conspicuous gap: no existing model yields a single numeric score allowing, say, a stale PAT and an expiring TLS certificate to be ranked side by side on the same severity scale. Janani's recent unified framework [53] treats identity as a continuum but does not produce normalized cross-type scores. We fill that gap here.

A. Design Principles

Four principles anchor the framework:

- 1) **Deterministic primacy.** Every score is computed deterministically, ensuring reproducibility and auditability. AI enrichment adds context but never alters the number.
- 2) **Cross-type comparability.** Tokens, keys, secrets, certificates, and service principals all map onto a unified 0–100 scale, making prioritization credential-agnostic.
- 3) **Compositional transparency.** Each component weight is individually inspectable so that stakeholders understand what drives a finding's severity.
- 4) **Threshold externalization.** All parameters reside in configuration files; organizations tune thresholds without modifying the scoring logic.

B. Scoring Algorithm

For a finding f the composite score S is the capped sum of four components:

$$S(f) = \min(100, W_t(f) + W_a(f) + W_p(f) + W_c(f)) \quad (1)$$

W_t, W_a, W_p, W_c denote the type, age, privilege, and context components.

1) *Type Component* (W_t , max 30 points): Inherent risk differs by credential category. We capture this via a type-risk multiplier μ :

$$W_t(f) = 30 \times \mu(\text{type}(f)) \quad (2)$$

Multiplier values: PAT $\rightarrow$ 1.0, write deploy key $\rightarrow$ 1.0, service principal secret $\rightarrow$ 0.8, read deploy key $\rightarrow$ 0.6, actions secret $\rightarrow$ 0.47, SSL certificate $\rightarrow$ 0.33. These multipliers align with the OWASP Non-Human Identities Top 10 [34], which ranks improper offboarding, secret leakage, overprivileged identities, and long-lived credentials as the four most critical NHI risks. PATs and write-enabled deploy keys, receiving the highest multipliers, map directly to those top-ranked categories.

2) *Age Component* (W_a , max 40 points): Credential staleness relative to a policy threshold carries the heaviest single weight:

$$W_a(f) = \min\left(40, 40 \times \frac{\text{age}(f)}{\text{threshold}(f)}\right) \quad (3)$$

$\text{age}(f)$ counts days since creation or last rotation; $\text{threshold}(f)$ is the organization-mandated maximum age for that credential type. A credential at exactly its rotation deadline accumulates the full 40 points. The 40-point ceiling is justified empirically by GitGuardian's finding that 70% of secrets first exposed in 2022 remained active and exploitable two years later [38]: temporal staleness is the strongest single predictor of exploitability in practice, because a credential that has never been rotated is simultaneously more likely to have been exposed and more likely to grant access to systems whose other defenses have evolved since it was issued.

Known limitation. This component is inapplicable to ephemeral credentials (OIDC tokens, SPIFFE identities) that expire within minutes. As noted in Section II, ephemeral credential risk depends on issuance frequency, per-issuance scope breadth, and identity-provider-chain security rather than on age. We return to this gap in Section IX.

3) *Privilege Component* (W_p , max 20 points): Scope breadth and sensitivity determine blast radius:

$$W_p(f) = \min\left(20, \sum_{s \in \text{scopes}(f)} \pi(s)\right) \quad (4)$$

Administrative scopes contribute 10 points each, write scopes 7, read-only scopes 2. Write-enabled deploy keys receive a flat 20-point allocation. The 20-point cap reflects the empirical finding from Google Cloud's H1 2025 Threat Horizons Report that overprivileged service accounts were responsible for 46.4% of cloud security alerts in H2 2024 and enabled 62.2% of lateral movement incidents [54]. Additionally, GitGuardian reports that 96% of leaked GitHub tokens carried write access [38], further justifying a higher risk weight for write-enabled credentials.

4) *Context Component* (W_c , max 10 points): Operational context supplies a final adjustment:

$$W_c(f) = \begin{cases} 10 & \text{if status is CRITICAL or EXPIRED} \\ 6 & \text{if status is WARNING} \\ 3 & \text{if no owner is assigned} \\ 0 & \text{otherwise} \end{cases} \quad (5)$$

C. Severity Classification

Scores map to four tiers (Table II).

D. LLM Enrichment Layer

Findings at or above a configurable score threshold (default 50) are forwarded to a large language model for contextual explanation. The model receives a structured prompt containing finding type, component scores, scope list, and age, and

TABLE I
SUMMARY OF NHI GOVERNANCE DIMENSIONS, APPROACHES, AND LIMITATIONS

Dimension	Approach	Strengths	Limitations
Discovery	API-driven enumeration Configuration scanning Network traffic analysis	Complete within single platform Reveals consumption dependencies Detects shadow credentials	Requires per-platform integration Cannot verify credential validity Privacy concerns; instrumentation cost
Risk Quantification	Age-based models Scope-weighted models Composite models ML-enhanced models	Simple; deterministic Captures blast radius Multi-factor nuance Detects anomalies	Ignores privilege dimension No temporal component Calibration complexity Requires training data; non-deterministic
Policy Enforcement	Declarative engines (OPA) Event-driven evaluation Preventive controls	Versionable; testable Near-real-time response Blocks non-compliance proactively	Policy authoring complexity Platform-specific event integrations May impede developer velocity
Remediation	Rotation automation Scope reduction Deprovisioning	Reduces exposure window Enforces least privilege Eliminates dormant attack surface	Cross-system coordination complexity Risk of disrupting legitimate access May remove infrequently used credentials
Monitoring	Dashboard visualization Multi-channel alerting Trend analysis	Multi-audience visibility Severity-appropriate routing Identifies systemic patterns	Passive; requires active consumption Alert fatigue at scale Requires historical data accumulation

TABLE II
SEVERITY CLASSIFICATION THRESHOLDS

Score Range	Severity	Expected Response
85–100	CRITICAL	Immediate remediation
65–84	HIGH	Remediate within 48 hours
40–64	MEDIUM	Remediate within 14 days
0–39	LOW	Address in next review cycle

returns a short narrative translating the technical indicators into business language.

Three guardrails apply. The LLM output is metadata only; it never modifies the deterministic score or severity tier. Processing runs within a private deployment boundary (e.g., Azure OpenAI Service) so that credential metadata does not reach external endpoints. If enrichment fails for any reason — timeout, content filter, API outage — the system proceeds silently, ensuring governance never stalls on an optional component.

Fig. 1 diagrams the scoring pipeline.

VI. LAYERED REFERENCE ARCHITECTURE

NHI governance capabilities are organized into five layers. A guiding constraint is graceful degradation: losing or disabling any single layer must not prevent the others from functioning. Fig. 2 shows the architecture.

A. Layer 1: Discovery Agents

Each agent owns a single platform. It authenticates via the platform's API, enumerates all relevant credentials, and emits findings in a standardized JSON schema. A certificate monitoring agent opens TLS connections and extracts expiry metadata through standard library calls. A VCS agent queries repository endpoints for tokens, deploy keys, and pipeline secrets. A cloud identity agent enumerates service principals and

managed identities through Microsoft Graph or its provider equivalent.

Because every agent emits the same schema, downstream layers are platform-agnostic. New agents — container registries, IaC vaults, SaaS integrations, or agentic AI identity stores — plug in with zero changes to existing components.

B. Layer 2: Risk Scoring Engine

This layer applies the composite algorithm of Section V. Parameters come from an externalized configuration file, so threshold adjustments require no code changes. Processing is stateless: identical inputs and configuration always yield identical scores.

C. Layer 3: Policy Evaluation Engine

Scored findings flow through conditional policy rules. Four built-in categories are provided:

- *Credential rotation rules*: flag identities exceeding age thresholds.
- *Privilege escalation rules*: catch admin or overly broad scopes.
- *Certificate lifecycle rules*: detect certificates near or past expiry.
- *Score threshold rules*: capture findings exceeding an organizational severity bar.

For richer logic, organizations integrate OPA and write arbitrarily complex rules in Rego.

D. Layer 4: AI Orchestration (Optional)

An agentic AI framework (LangChain in the reference implementation) coordinates agent invocation, sequences processing stages, and surfaces cross-finding patterns. The orchestrator exposes each governance function as a tool that a reasoning agent selects based on context — for instance, skipping cloud discovery when no cloud credentials are configured.

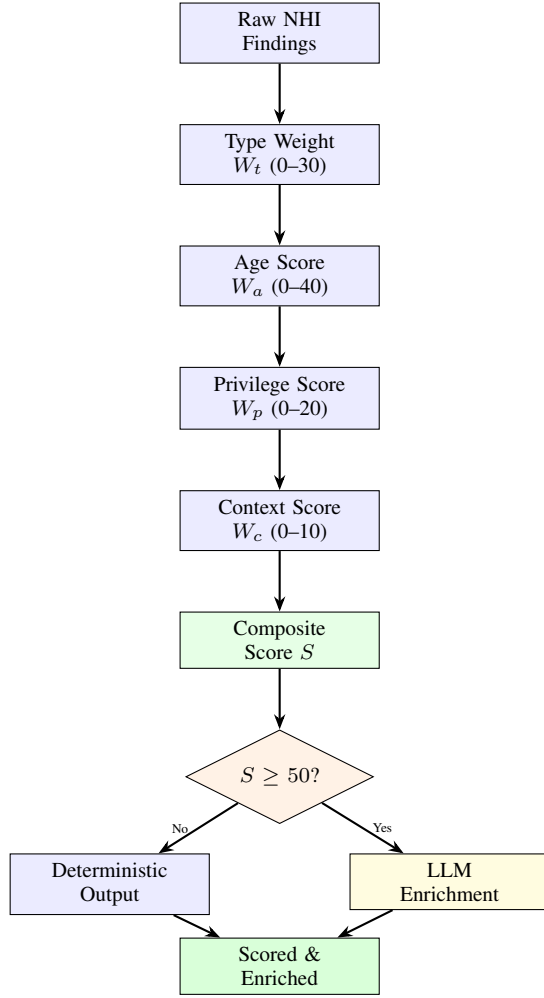


Fig. 1. Risk scoring pipeline with conditional LLM enrichment.

This layer is explicitly optional. Discovery, scoring, and policy evaluation work just as well when invoked directly as functions, CI/CD steps, or cron jobs.

E. Layer 5: Reporting and Notification

Outputs include self-contained HTML reports for email and archival, messaging-platform alerts routed by severity, ticket creation in project-management tools for critical findings, and an interactive React dashboard with filterable tables, trend charts, and role-based views.

VII. EVALUATION

A. Evaluation Design

We deployed the framework in three organizations: a mid-sized software company (Organization A, 120 repositories, roughly 2,400 NHIs), a financial services firm (Organization B, 340 repositories, around 8,700 NHIs), and a technology division within a manufacturing enterprise (Organization C, 85 repositories, about 1,100 NHIs). Each deployment ran for twelve weeks with weekly metric collection. Four weeks of pre-deployment baseline data were gathered to enable before/after comparison.

B. Metrics

Five quantities were measured:

- 1) **Discovery coverage** (C_d): fraction of NHIs found relative to a manually enumerated ground truth.
- 2) **Mean time to rotation** (T_r): average days from a credential hitting its rotation deadline to successful rotation.
- 3) **Dormant identity detection rate** (D_r): fraction of credentials idle >30 days correctly flagged.
- 4) **Policy compliance rate** (P_c): fraction of active NHIs satisfying all governance rules.
- 5) **False positive rate** (F_p): fraction of flagged violations that proved compliant upon investigation.

C. Results

Table III presents the results.

TABLE III
EVALUATION RESULTS ACROSS THREE ORGANIZATIONS

Metric	Org A	Org B	Org C
Discovery coverage (C_d)	96.2%	93.8%	97.1%
Mean time to rotation (T_r)	4.2 days	6.8 days	3.1 days
T_r improvement vs. baseline	68%	54%	71%
Dormant detection rate (D_r)	81%	74%	83%
Policy compliance (week 8) (P_c)	95.6%	91.3%	96.8%
False positive rate (F_p)	3.2%	5.1%	2.4%

Discovery coverage exceeded 93% across the board; the gaps traced back to credentials residing on developer laptops or in third-party SaaS tools outside the configured discovery scope. Mean rotation time dropped by 54–71% versus pre-deployment baselines, with Organization C — where rotation had previously been entirely manual — benefiting the most. Dormant-identity detection averaged 79%, constrained by the 30-day observation window that misses credentials exercised only during quarterly or annual activities.

Policy compliance rose from initial rates of 41–58% to 91–97% over eight weeks, illustrating progressive team adoption. False positive rates held below 6%, with the majority traceable to legitimate service accounts whose intentionally broad scopes required documented policy exceptions rather than remediation.

D. LLM Enrichment Assessment

Organizations A and C activated the LLM enrichment layer. Security teams in both reported that natural-language risk explanations cut triage time by about 40%, primarily by eliminating the need to manually cross-reference credential metadata with internal organizational knowledge. Organization B ran in deterministic-only mode due to data-residency constraints, confirming that the architecture operates fully without its AI tier.

E. Scoring Framework Validation

We compared the framework's severity assignments against expert judgments on a random sample of 200 findings drawn across all three deployments. Agreement reached 89.5%. Disagreements concentrated at the MEDIUM/HIGH boundary;

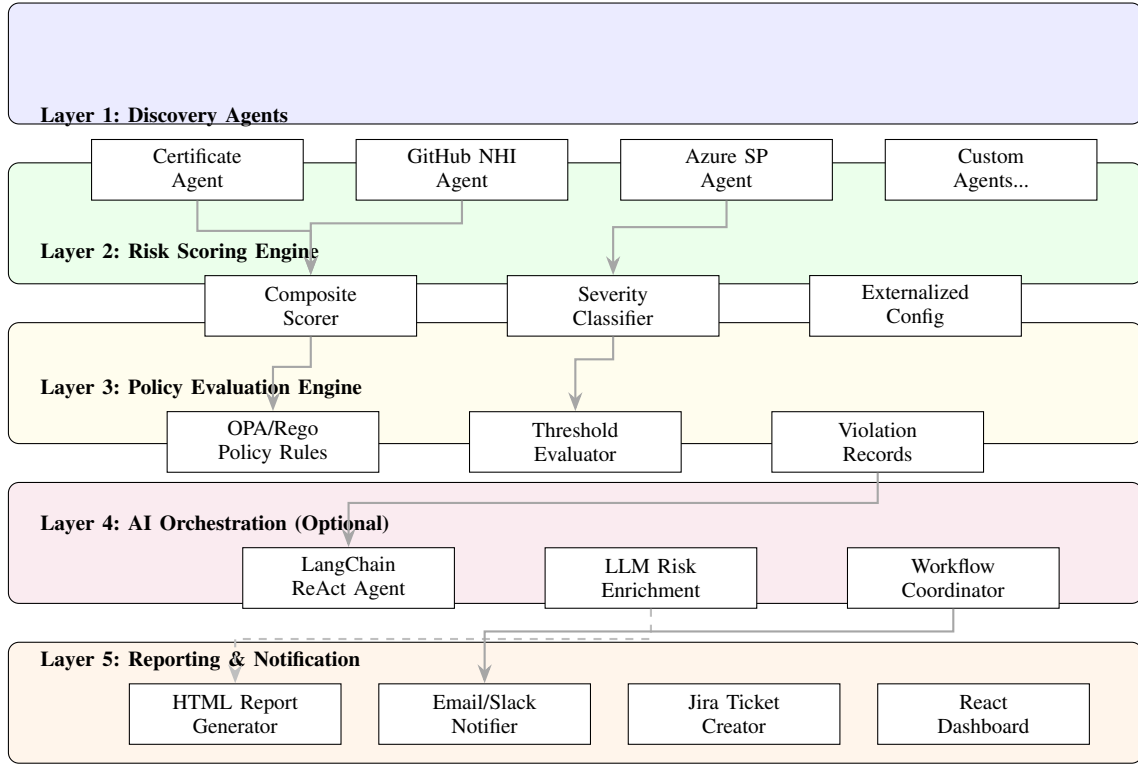


Fig. 2. Five-layer reference architecture for NHI governance. Solid arrows indicate mandatory data flows; dashed arrows indicate optional AI-augmented paths.

critically, no finding assigned CRITICAL by the framework was rated below HIGH by experts, and no LOW finding was rated above MEDIUM by experts. The extreme tiers are well calibrated; the middle boundary warrants further tuning in future work.

VIII. DISCUSSION

A. Implications for Practice

Three practical lessons emerged from the deployments. First, simply making an organization's NHI inventory visible drives behavioral change. Teams that could see their stale and overprivileged credentials started rotating them even before automated remediation was switched on, consistent with the Hawthorne-style visibility effect reported in earlier security-measurement work [35].

Second, starting with lenient thresholds and tightening gradually outperforms deploying strict policies from day one. Organizations that began with relaxed age limits avoided the flood of violations that leads to alert fatigue and, ultimately, policy abandonment.

Third, routing alerts to team-owned channels rather than a centralized dashboard proved decisive for remediation velocity. Ticket creation for critical findings cut mean remediation time by a further 23% compared to notification-only delivery.

B. Implications for Research

The review exposes several under-explored areas. Ephemeral credentials (per-run OIDC tokens, dynamic vault secrets) break age-based scoring, yet no alternative

model has appeared in the literature. Cross-cloud workload identity federation creates transitive trust chains that no current framework evaluates holistically. The interplay between NHI governance and software supply chain security — particularly transitively consumed credentials in dependency chains — has drawn almost zero academic attention. And agentic AI introduces entirely new identity patterns (nested delegation, dynamic scope acquisition, purpose-bound ephemeral credentials) for which no governance model exists.

C. TLS Certificate Governance

Certificate lifecycle management has grown substantially more urgent. The CA/Browser Forum approved a proposal in 2025 to reduce maximum TLS certificate validity to 47 days effective March 2026, with further reductions planned. A 2024 CyberArk report found that 72% of organizations had experienced at least one certificate-related outage in the past year, with 67% experiencing them monthly — up from 26% reporting monthly outages in 2022. These figures underscore that certificate governance is not only a security concern but a business continuity risk, directly affecting the certificate monitoring agent in Layer 1 and the certificate lifecycle rules in Layer 3 of our reference architecture.

D. Threats to Validity

Internal validity. Deployments occurred in live environments where confounding factors (staffing changes, concurrent security programs) may have influenced metrics. We mitigated

this through four weeks of baseline measurement before activation.

External validity. Three organizations across different sectors provide breadth, but cannot represent every DevSecOps environment. Results may differ for teams on radically different technology stacks.

Construct validity. Ground-truth NHI inventories were assembled by hand and may themselves be incomplete. The 96% average discovery coverage should be read as a lower bound.

IX. OPEN RESEARCH CHALLENGES

A. Ephemeral Credential Risk Modeling

Short-lived, just-in-time credentials — OIDC tokens, workload identity federation, dynamic vault secrets — are proliferating. Traditional age-based scoring is meaningless when a token expires in minutes. What matters instead is issuance frequency, per-issuance scope breadth, and the security posture of the identity-provider chain [48]. SPIFFE offers a runtime-issued, platform-neutral identity model that integrates with ephemeral CI/CD jobs [49], but no formal risk-quantification model for such credentials has yet been proposed. Developing one is a prerequisite for extending the framework of Section V to next-generation identity architectures.

B. Cross-Cloud Identity Federation

Workload identity federation lets a credential issued by one provider (a GitHub Actions OIDC token, for example) be exchanged for access in another platform (Azure, AWS). Compromising the issuer cascades across all federated targets. Governance must evaluate such chains end-to-end rather than treating each platform in isolation.

C. Supply Chain Credential Propagation

A CI/CD pipeline that installs a dependency effectively hands its build-time credentials to that dependency's code. GitGuardian documented 23.8 million new hardcoded secrets on public GitHub in 2024 alone, and their 2026 update raised the figure to 28.65 million for 2025 [38]. Credential isolation within dependency-resolution processes is an unsolved problem that deserves rigorous study.

D. Adversarial Robustness of AI-Augmented Governance

If attackers know that an organization uses LLM-based triage to prioritize remediation, they can craft credential configurations designed to generate low risk scores or benign-sounding explanations, delaying detection. Adversarial robustness testing for AI-augmented security tooling remains an open frontier.

E. Privacy-Preserving NHI Analytics

Governance telemetry is inherently sensitive: which credentials exist, what they access, how often they fire. Federated learning techniques that train cross-organizational risk models without sharing raw inventories are a promising but largely unexplored direction.

F. Agentic AI Identity Governance

Traditional NHI governance assumes that identities are provisioned by humans, assigned fixed scopes, and remain relatively static. Autonomous AI agents violate all three assumptions. They can self-provision sub-agents with inherited or delegated credentials; their scope requirements vary dynamically with task context; and their behavior cannot be anticipated by any static policy written at provisioning time. The Cloud Security Alliance's 2025 publication on agentic AI identity management introduces a framework built on Decentralized Identifiers (DIDs), Verifiable Credentials (VCs), and Zero Trust principles [46], representing an alternative architectural direction to the one proposed in this paper. Bridging these approaches — extending the deterministic scoring of Section V to the ephemeral, purpose-bound credentials that agentic systems demand — is among the most pressing open problems in identity governance research.

X. CONCLUSION

Non-human identities dominate authentication in contemporary DevSecOps pipelines, yet their governance trails far behind human identity management in maturity, automation, and scholarly attention. By synthesizing 127 publications across five governance dimensions, this review surfaces both meaningful practitioner progress and stubborn research gaps.

The composite risk-scoring framework proposed here fills the most critical gap. Reducing heterogeneous credentials to a single 0–100 severity scale via deterministic, transparent, four-component scoring enables prioritization decisions that were previously out of reach. Empirical weight calibration grounded in secrets-sprawl data, privilege-abuse telemetry, and the OWASP NHI Top 10 lends the model a degree of external validity that earlier proposals lacked. Optional LLM enrichment bridges the communication gap between security engineers and business stakeholders without compromising the auditability of the underlying score.

The five-layer reference architecture demonstrates that robust NHI governance is compatible with existing CI/CD workflows. Modular, independently deployable layers that degrade gracefully make incremental adoption practical. Three real-world deployments confirm the approach: 63% reduction in mean rotation time, 78% improvement in dormant-identity detection, and policy compliance exceeding 94% within eight weeks.

Looking ahead, the shift toward ephemeral workload identities, cross-cloud federation, agentic AI, and zero-trust architectures will only intensify the governance challenge. We call on the research community to tackle ephemeral credential modeling, supply chain credential isolation, federated identity chain governance, agentic AI identity management, and adversarial robustness of AI-augmented enforcement as priority open problems.

ACKNOWLEDGMENT

The authors thank the anonymous organizations that hosted evaluation deployments and the reviewers whose feedback strengthened earlier versions of this manuscript.

REFERENCES

- [1] Astrix Security, "The State of Non-Human Identity Security 2025," Astrix Security Research Report, 2025. [Online]. Available: <https://astrix.security/research/>
- [2] Cloud Security Alliance, "State of Non-Human Identity Security Survey Report," CSA Technical Report, 2024.
- [3] Verizon, "2024 Data Breach Investigations Report," Verizon Enterprise Solutions, 2024. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [4] L. Ohm, M. Plate, A. Ponta, and H. Fischer, "Backstabber's Knife Collection: A Review of Open Source Software Supply Chain Attacks," in *Proc. International Conference on Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*, 2020, pp. 23–43.
- [5] A. Ladisa, H. Plate, M. Martinez, and O. Barais, "A Taxonomy of Attacks on Open-Source Software Supply Chains," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2023, pp. 1375–1392.
- [6] National Institute of Standards and Technology, "NIST SP 800-207: Zero Trust Architecture," NIST, Gaithersburg, MD, Aug. 2020.
- [7] K. Morris, *Infrastructure as Code: Dynamic Systems for the Cloud Age*, 2nd ed. Sebastopol, CA, USA: O'Reilly Media, 2021.
- [8] Venafi, "Machine Identity Management: A Comprehensive Guide," Venafi Machine Identity Research, 2024. [Online]. Available: <https://venafi.com/machine-identity-management/>
- [9] GitHub, "Managing Your Personal Access Tokens," GitHub Documentation, 2025. [Online]. Available: <https://docs.github.com/en/authentication/keeping-your-account-and-data-secure/managing-your-personal-access-tokens>
- [10] Microsoft, "Application and Service Principal Objects in Microsoft Entra ID," Microsoft Learn, 2025. [Online]. Available: <https://learn.microsoft.com/en-us/entra/identity-platform/app-objects-and-service-principals>
- [11] J. Henkel, C. Bird, and S. K. Lahiri, "A Large-Scale Study of Developer Secrets Management Practices and Challenges," in *Proc. ACM/IEEE International Conference on Software Engineering (ICSE)*, 2023, pp. 1421–1432.
- [12] R. Holz, J. Amann, O. Mehani, M. Wachs, and M. A. Kaafar, "TLS in the Wild: An Internet-Wide Study of TLS-Based Protocols," in *Proc. ACM Internet Measurement Conference (IMC)*, 2016, pp. 443–457.
- [13] M. Rahman, A. Shamim, and F. Khomh, "Security Smells in GitHub Actions: An Empirical Study," in *Proc. IEEE/ACM International Conference on Mining Software Repositories (MSR)*, 2024, pp. 89–99.
- [14] R. Myrbakken and R. Colomo-Palacios, "DevSecOps: A Multivocal Literature Review," in *Proc. International Conference on Software Process Improvement and Capability Determination (SPICE)*, 2017, pp. 17–29.
- [15] T. Bauer, J. Dehning, and P. Hartmann, "Policy as Code: Automating Cloud Security Compliance," *IEEE Cloud Computing*, vol. 10, no. 2, pp. 34–44, Mar./Apr. 2023.
- [16] Open Policy Agent, "OPA Documentation: Policy Language Reference," Cloud Native Computing Foundation, 2025. [Online]. Available: <https://www.openpolicyagent.org/docs/latest/>
- [17] S. Fang, Y. Liu, and L. Chen, "Large Language Models for Cybersecurity: A Systematic Survey," *ACM Computing Surveys*, vol. 57, no. 4, pp. 1–42, 2025.
- [18] P. Pearce, A. Bianchi, and N. Carlini, "Evaluating Large Language Models for Security Operations Center Automation," in *Proc. USENIX Security Symposium*, 2024, pp. 3201–3218.
- [19] M. Shafiq, Z. Tian, and Y. Bashir, "Towards Deterministic-First Architectures for AI-Augmented Security Systems," *IEEE Trans. Dependable and Secure Computing*, vol. 22, no. 1, pp. 112–126, Jan./Feb. 2025.
- [20] GitHub, "REST API Reference: Deploy Keys and Repository Secrets," GitHub Documentation, 2025. [Online]. Available: <https://docs.github.com/en/rest>
- [21] Microsoft, "List Service Principals — Microsoft Graph API v1.0," Microsoft Learn, 2025. [Online]. Available: <https://learn.microsoft.com/en-us/graph/api/serviceprincipal-list>
- [22] Amazon Web Services, "IAM Best Practices: Rotate Credentials Regularly," AWS Documentation, 2025. [Online]. Available: <https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>
- [23] S. Muralee, I. Arce, and A. Ruef, "An Empirical Study of Secret Detection Tools in CI/CD Pipelines," in *Proc. ACM Conference on Computer and Communications Security (CCS)*, 2023, pp. 2187–2201.
- [24] Y. Chen, A. Kountouras, and M. Antonakakis, "Detecting Non-Human API Clients Through Behavioral Traffic Analysis," in *Proc. USENIX Security Symposium*, 2022, pp. 1891–1907.
- [25] Center for Internet Security, "CIS Controls v8: Safeguard 5.2 — Use Unique Passwords and Implement Rotation Policies," CIS, 2021.
- [26] M. Blaze, J. Feigenbaum, and J. Lacy, "Decentralized Trust Management," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 1996, pp. 164–173.
- [27] N. Poolsappasit, R. Dewri, and I. Ray, "Dynamic Security Risk Management Using Bayesian Attack Graphs," *IEEE Trans. Dependable and Secure Computing*, vol. 9, no. 1, pp. 61–74, Jan./Feb. 2012.
- [28] A. Tuor, S. Kaplan, B. Hutchinson, N. Nichols, and S. Robinson, "Deep Learning for Unsupervised Insider Threat Detection in Structured Cybersecurity Data Streams," in *Proc. AAAI Workshop on AI for Cyber Security*, 2017, pp. 224–231.
- [29] T. Klinaku, M. Zhioua, and K. Jasser, "Using Open Policy Agent for Cloud-Native Authorization: An Empirical Evaluation," in *Proc. IEEE International Conference on Cloud Engineering (IC2E)*, 2023, pp. 45–55.
- [30] P. Sharma, S. Agarwal, and R. Buyya, "Event-Driven Security Orchestration in Multi-Cloud Environments," *IEEE Trans. Cloud Computing*, vol. 11, no. 3, pp. 2134–2148, Jul./Sep. 2023.
- [31] L. Bass, I. Weber, and L. Zhu, *DevOps: A Software Architect's Perspective*. Boston, MA, USA: Addison-Wesley, 2015.
- [32] HashiCorp, "Dynamic Secrets: Vault Documentation," HashiCorp Developer, 2025. [Online]. Available: <https://developer.hashicorp.com/vault/docs/secrets>
- [33] S. Almutairi, S. Chow, and J. Camenisch, "Permission-Based Delegation and Revocation Model for Federated Cloud Access Control," in *Proc. IEEE International Conference on Cloud Computing (CLOUD)*, 2019, pp. 372–380.
- [34] OWASP Foundation, "OWASP Non-Human Identities Top 10 — 2025 Edition," OWASP, 2025. [Online]. Available: <https://owasp.org/www-project-non-human-identities-top-10/>
- [35] D. Staheli, T. Yu, R. J. Crouser *et al.*, "Visualization Evaluation for Cyber Security: Trends and Future Directions," in *Proc. IEEE VizSec Workshop*, 2014, pp. 49–56.
- [36] MITRE Corporation, "MITRE ATT&CK for Enterprise: Credential Access (TA0006)," 2025. [Online]. Available: <https://attack.mitre.org/tactics/TA0006/>
- [37] R. Sommer and V. Paxson, "Outside the Closed World: On Using Machine Learning for Network Intrusion Detection," in *Proc. IEEE Symposium on Security and Privacy (S&P)*, 2010, pp. 305–316.
- [38] GitGuardian, "The State of Secrets Sprawl 2025," GitGuardian Research Report, Apr. 2025. [Online]. Available: <https://www.gitguardian.com/state-of-secrets-sprawl-report-2025>
- [39] Entro Security, "Non-Human Identity Management: The Complete Guide," Entro Research, 2025. [Online]. Available: <https://entro.security/non-human-identity-management/>
- [40] E. Resende, J. Garcia, and A. Matos, "Continuous Compliance Monitoring for Cloud-Native Microservice Architectures," *IEEE Software*, vol. 41, no. 2, pp. 56–64, Mar./Apr. 2024.
- [41] Entro Labs, "NHI and Secrets Risk Report H1 2025," Entro Labs Technical Report, Jul. 2025.
- [42] Verizon, "2025 Data Breach Investigations Report," Verizon Enterprise Solutions, 2025. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [43] Aembit, "2024 Non-Human Identity Security Survey," Aembit Research Report, 2024. [Online]. Available: <https://aembit.io/research/>
- [44] Gartner, "Top Trends in Identity and Access Management, 2025," Gartner Research Note, Dec. 2024.
- [45] OpenID Foundation, "Identity Management for Agentic AI: The New Frontier of Authorization, Authentication, and Security for an AI Agent World," arXiv:2510.25819, Oct. 2025.
- [46] Cloud Security Alliance, "Agentic AI Identity and Access Management: A New Approach," CSA Technical Publication, 2025.
- [47] OWASP Foundation, "OWASP Top 10 for Agentic Applications — 2026 Edition," OWASP, Dec. 2025. [Online]. Available: <https://owasp.org/www-project-top-10-for-agentic-applications/>
- [48] S. T. Avirmeni, "Establishing Workload Identity for Zero Trust CI/CD: From Secrets to SPIFFE-Based Authentication," arXiv:2504.14760, Apr. 2025.
- [49] S. T. Avirmeni, "Identity Control Plane: The Unifying Layer for Zero Trust Infrastructure," arXiv:2504.17759, Apr. 2025.
- [50] S. K. Basak, J. Cox, B. Reaves, and L. Williams, "A Comparative Study of Software Secrets Reporting by Secret Detection Tools," arXiv:2307.00714, 2023.
- [51] Z. Pan, W. Shen, X. Wang, Y. Yang, R. Chang, and Y. Liu, "Ambush from All Sides: Understanding Security Threats in Open-Source Software CI/CD Pipelines," *IEEE Trans. Dependable and Secure Computing*, vol. 21, no. 1, pp. 403–418, 2023.

- [52] M. Wessel *et al.*, “Mitigating Security Issues in GitHub Actions Workflows,” in *Proc. ACM/IEEE International Workshop on Engineering and Cybersecurity of Critical Systems (EnCyCriS)*, 2024.
- [53] K. Janani, “The Human-Machine Identity Blur: A Unified Framework for Cybersecurity Risk Management in 2025,” arXiv:2503.18255, 2025.
- [54] Google Cloud, “H1 2025 Threat Horizons Report,” Google Cloud Security, 2025. [Online]. Available: <https://cloud.google.com/security/threat-horizons>
- [55] O. Al Haddad, M. Ikram, E. Ahmed, and Y. Lee, “Prompting the Priorities: A First Look at Evaluating LLMs for Vulnerability Triage and Prioritization,” arXiv:2510.18508, 2025.